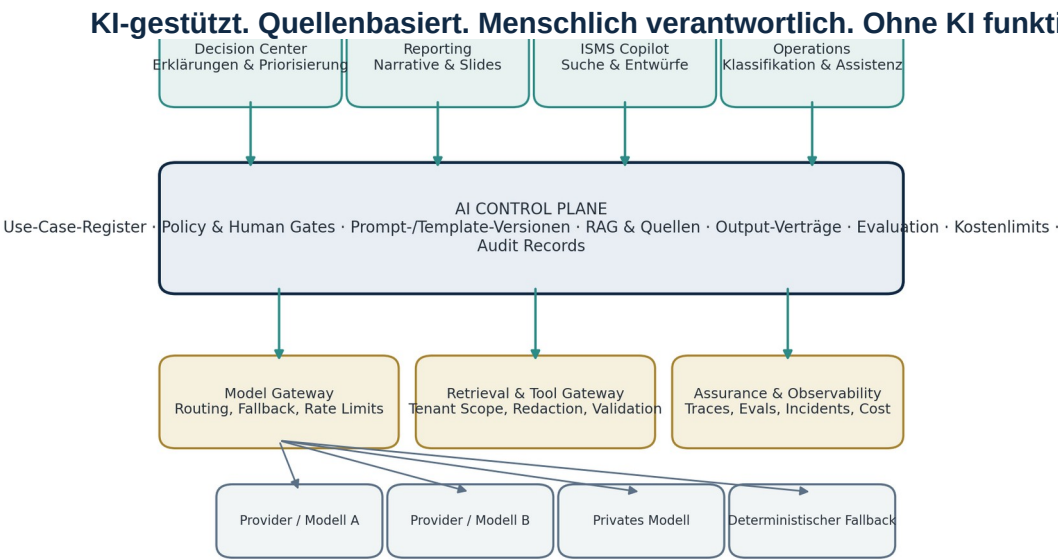


KI-Funktionen & Guardrails

Realisierbare KI-Fähigkeiten, Human Gates, Provider- und Datenkontrollen, Evaluation, Prompt-/RAG-Sicherheit, Fallbacks und nachvollziehbare AI Assurance.



ARBEITSBEZEICHNUNG ISMS Managed Service Platform
VERSION 1.0
STATUS Erstellt
STAND 22.07.2026
ABHÄNGIGKEITEN Dokument 00 bis 19

Dokumentauftrag & Verbindlichkeit

Dokument 20A ist die verbindliche Produkt-, Architektur-, Sicherheits- und Qualitätsquelle für KI-Funktionen. Es definiert, welche Fähigkeiten zulässig sind, welche Entscheidungen menschlich bleiben, wie Modellprovider und Datenwege kontrolliert werden und wie der Demonstrator auch ohne externen API-Zugang vollständig funktioniert.

Steuerungsfeld	Festlegung
Dokument-ID	20A
Status	Erstellt - Version 1.0
Owner	AI Product Owner / AI Risk Owner / Product Security
Gültigkeit	Bis zur freigegebenen Nachfolgeversion
Datenstatus	Demo-, Test- und Golden-Set-Daten sind synthetisch; produktive Provider- und Rechtsfreigaben bleiben offen.
Änderungskontrolle	Änderungen an Autonomie, Human Gates, Provider Policy, Retrievalberechtigung, Tool Agency, Datenklassen, Training Use oder externem Publishing benötigen AI-, Security-, Privacy- und Product-Impactanalyse.

Inhalt

1 Auftrag · 2 Summary · 3 Verfassung · 4 Fähigkeiten · 5 Autonomie · 6 Register · 7 Use Cases · 8 Risiko · 9-12 Anfrage, Control Plane, Provider und Modellregister · 13-16 RAG, Prompts, Outputs, Provenance · 17-20 Human Gates, Tools, Security und Datenschutz · 21-27 Kosten, Evaluation, Monitoring, Incidents, Fallback und UX · 28-32 Fachspezifikation, Managed Services, Demo und Fehlerfälle · 33-40 Akzeptanz, Entscheidungen, Annahmen, offene Fragen, Ideen, Abhängigkeiten, Quellen und Änderungen.

1. Auftrag und Abgrenzung

Dokument 20A ist die kanonische Quelle für die produktseitige Nutzung künstlicher Intelligenz in der ISMS Managed Service Platform. Es legt fest, **wo KI einen belegbaren Mehrwert liefern darf, welche Funktionen ohne KI funktionsfähig bleiben, wie Daten und Berechtigungen geschützt werden, wie Modellausgaben geprüft werden und wann menschliche Autorität zwingend erforderlich ist.**

Das Dokument beantwortet insbesondere:

- Welche KI-Funktionen sind für das Produkt nützlich, technisch realistisch und für den Demonstrator umsetzbar?
- Welche fachlichen Kernfunktionen bleiben deterministisch und dürfen nicht von generativer KI abhängen?
- Wie werden KI-Anwendungsfälle nach Wirkung, Datenklasse und Autonomiebedarf klassifiziert?
- Wie funktionieren Model Gateway, Retrieval, Prompt Management, strukturierte Outputs und Provider-Fallbacks?
- Wie werden Tenant Scope, Rollen, Zweckbindung, Datenminimierung, Quellen und Modellzugriff kontrolliert?
- Wie schützt sich die Plattform vor Prompt Injection, Datenabfluss, unsicheren Tool Calls, Halluzinationen und unkontrolliertem Verbrauch?
- Wie werden Confidence, Quellenlage, Unsicherheit, menschliche Prüfung und Overrides sichtbar gemacht?
- Wie werden Qualität, Sicherheit, Kosten und Drift vor Freigabe und im laufenden Betrieb gemessen?
- Wie bleibt der private Demonstrator vollständig vorführbar, wenn kein externer KI-API-Schlüssel verfügbar ist?

Nicht Gegenstand dieses Dokuments sind die Rollen und Kommunikationsstruktur der virtuellen KI-Firma aus Dokument 20B sowie Repository, Claude-Code-Sessions, Checkpoints, Tests und Bauphasen aus Dokument 20C. Die allgemeine Plattformarchitektur aus Dokument 18 und alle Sicherheits-, Datenschutz-, Rechte- und Auditgrenzen aus Dokument 19 bleiben verbindlich.

2. Executive Summary

Die Plattform wird **KI-gestützt, aber nicht KI-abhängig**. Reifegrad, Risikologik, Control-Wirksamkeit, Zielrouten, Rollen, Statusübergänge, Berechtigungen, Freigaben, Audit Records und Managed-Service-SLAs funktionieren deterministisch. KI erklärt, verdichtet, klassifiziert, entwirft, sucht, vergleicht und schlägt vor. Sie darf diese fachlichen Wahrheiten nicht heimlich ersetzen.

Jeder KI-Anwendungsfall besitzt einen Eintrag im **AI Use Case Register** mit Owner, Zweck, Nutzer, Datenklassen, Autonomiestufe, Risikoklasse, erlaubten Modellen, Human Gate, Qualitätszielen, Testsets, Kostenbudget, Fallback und Abschaltregel. Ein zentraler **AI Control Plane** erzwingt diese Verträge vor jedem Modellaufruf.

Kritische Produktaktionen bleiben menschlich freigabepflichtig. Dazu gehören insbesondere Risikoakzeptanz, Löschung, Export vertraulicher Daten, Rollenänderungen, Break Glass, verbindliche externe Kommunikation, Produktivfreigabe, Vertrags- oder Preisentscheidung und Abschluss einer wesentlichen Wirksamkeitsprüfung. KI kann diese Entscheidungen vorbereiten, begründen und dokumentieren, aber nicht final autorisieren.

Für den Demonstrator wird eine austauschbare KI-Schicht gebaut. Ist ein freigegebener Modellprovider konfiguriert, nutzt sie echte Modellaufrufe. Fehlt er oder ist er gestört, liefert ein **deterministischer Demo Adapter** reproduzierbare, klar als simuliert gekennzeichnete Ergebnisse aus synthetischen Daten. Dadurch bleibt die gesamte Produktreise vorführbar und testbar.

3. Verbindliche KI-Produktverfassung

- **AI01 - Purpose before Model:** Ein Modell wird erst ausgewählt, nachdem Zweck, Nutzer, gewünschter Output und Risikoklasse definiert sind.
- **AI02 - Core without Generative AI:** Kein kritischer Kernprozess ist ausschließlich von generativer KI abhängig.
- **AI03 - Proposal, not Truth:** KI-Ausgaben sind Vorschläge, Erklärungen oder Entwürfe und keine neue fachliche Systemwahrheit.
- **AI04 - Tenant and Purpose Bound:** Jeder Aufruf trägt Tenant Context, Nutzeridentität, Rolle, Zweck, Use-Case-ID und zulässigen Datenraum.
- **AI05 - Minimum Necessary Context:** Das Modell erhält nur die für den konkreten Zweck erforderlichen Daten.
- **AI06 - Evidence over Eloquence:** Flüssige Sprache ist kein Qualitätsnachweis. Materiale Aussagen benötigen Quellen, Regeln oder Datenbezug.
- **AI07 - Human Authority:** Wesentliche oder irreversible Entscheidungen bleiben beim Menschen.
- **AI08 - Structured by Default:** Maschinenrelevante Ausgaben verwenden validierte Schemas statt unkontrollierten Freitexts.
- **AI09 - Explainable Operation:** Modell, Provider, Zeitpunkt, Datenquellen, Promptversion, Validatoren, Confidence und Reviewstatus sind nachvollziehbar.
- **AI10 - Safe Retrieval:** Berechtigungen werden beim Retrieval erneut geprüft; Dokumentinhalte dürfen keine Systeminstruktionen überschreiben.
- **AI11 - Provider Portability:** Fachfunktionen werden nicht an einen einzelnen Modellprovider gekoppelt.
- **AI12 - Bounded Agency:** Tools und externe Aktionen sind allowlist-basiert, minimal berechtigt, reversible bevorzugt und separat freigegeben.
- **AI13 - Test before Trust:** Neue Modelle, Prompts, Retrieval-Änderungen und Tools durchlaufen risikobasierte Evaluation und Regressionstests.
- **AI14 - Graceful Degradation:** Ausfall, Kostenlimit oder Qualitätsproblem führt zu Fallback, manueller Bearbeitung oder Abschaltung, nicht zu erfundenen Ergebnissen.
- **AI15 - No Silent Learning:** Kundendaten werden standardmäßig nicht zum Training oder Fine-Tuning externer Modelle verwendet.
- **AI16 - Continuous Assurance:** Qualität, Sicherheit, Kosten, Drift, Beschwerden und Incidents werden laufend überwacht.
- **AI17 - Visible AI:** Nutzer erkennen, wann Inhalt KI-generiert oder wesentlich KI-verändert ist und was menschlich geprüft wurde.
- **AI18 - Correctability:** Nutzer können Entwürfe bearbeiten, ablehnen, begründen und als Feedback zurückgeben.
- **AI19 - Proportional Control:** Je höher Wirkung, Datenempfindlichkeit und Autonomie, desto strengere Modelle, Tests, Freigaben und Logging.
- **AI20 - Killable by Design:** Jeder Use Case, Provider, Modelltyp und Toolpfad besitzt einen kontrollierten Kill Switch.

3.1 Bewusst ausgeschlossene Muster

- KI als unsichtbare Quelle eines Risiko-, Reifegrad- oder Compliance-Scores,
- direkte Modellaufrufe aus Browser oder Fachmodul ohne Control Plane,
- unbeschränkte Übergabe kompletter Tenantdaten oder Evidence Rooms,
- ein universeller Systemprompt für alle Rollen und Kunden,
- autonome Risikoakzeptanz, Löschung, Export oder externe Veröffentlichung,
- Übernahme von Quelleninstruktionen aus Dokumenten, Webseiten oder Tickets,
- Tool Calls ohne Schema, Policy und serverseitige Autorisierung,
- Speicherung von Secrets, Access Tokens oder vollständigen Prompts in Standardlogs,
- Training mit Kundendaten als Opt-out-Standard,
- Confidence als bloße Selbsteinschätzung des Sprachmodells,
- Freigabe eines Use Cases nur anhand einer überzeugenden Einzeldemo,
- automatischer Wechsel auf ein schwächer geschütztes Modell bei Störung,
- versteckte Kosten ohne Token-, Request- und Budgetgrenzen,
- anthropomorphe Darstellung, die menschliche Verantwortlichkeit verschleiert.

4. KI-Fähigkeitsmodell

Die Plattform unterscheidet vier Fähigkeitsfamilien. Sie können unterschiedliche Modelle oder vollständig deterministische Verfahren verwenden.

Familie	Zweck	typische Outputs	Grundsatz
Language Assistance	erklären, zusammenfassen, formulieren, übersetzen	Textentwurf, Zusammenfassung, Klartext	Quellen und Review bei materialer Aussage
Knowledge Assistance	suchen, vergleichen, verknüpfen, zitieren	Treffer, Evidence-Bezug, Antwort mit Quellen	tenantbezogenes Retrieval und Berechtigungsprüfung

Familie	Zweck	typische Outputs	Grundsatz
Analytical Assistance	klassifizieren, priorisieren, Anomalien und Muster markieren	Label, Kandidat, Begründung, Ranking	deterministische Fachlogik bleibt maßgeblich
Action Assistance	Workflow, Report oder Entscheidung vorbereiten	strukturierter Entwurf, Tool-Plan, Work Package	bounded agency und Human Gate

ENTSCHEIDUNG: Generative KI wird nicht als fünfte Fachdomäne dargestellt. Sie ist eine kontrollierte Querschnittsfähigkeit innerhalb bestehender Module.

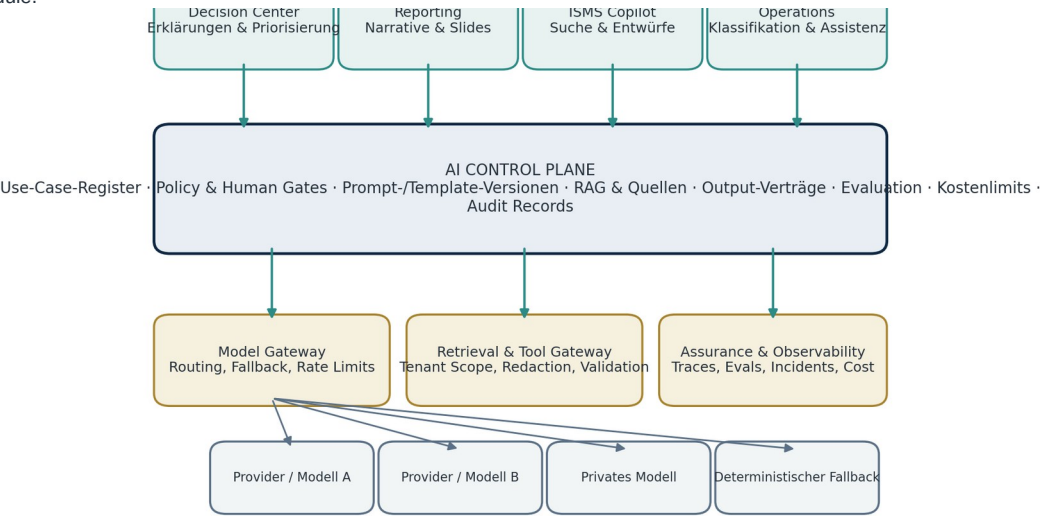


Abbildung 1: Produktfähigkeiten greifen nicht direkt auf Modelle zu. AI Control Plane, Model Gateway, Retrieval, Tooling, Assurance und Fallbacks bilden die kontrollierte Zwischenschicht.

5. Autonomie- und Wirkungsebenen

Stufe	Bedeutung	erlaubtes Verhalten	Standardfreigabe
A0	keine KI	deterministische Berechnung, Regel oder Template	bestehende Fachfreigabe
A1	Assistieren	suchen, erklären, zusammenfassen, übersetzen	Nutzer sieht Quellen und Grenzen
A2	Entwerfen	Bericht, Maßnahme, Mapping oder Antwort vorschlagen	Nutzer prüft vor Übernahme
A3	Vorbereiten	vollständigen Workflow, Entscheidung oder Report zur Freigabe vorbereiten	benannter Reviewer oder Approver
A4	kontrolliert ausführen	nur risikoarme, reversible, policyerlaubte Aktion	explizite Use-Case-Policy; kritische Aktionen ausgeschlossen

A4 ist bewusst eng. Erlaubt sein können beispielsweise das Erstellen eines internen Entwurfstasks, das Taggen eines synthetischen Demoobjekts oder das Starten einer freigegebenen Neuberechnung. Nicht erlaubt sind Risikoakzeptanz, Löschung, Änderung von Rechten, externer Versand, Vertragsfreigabe, Break Glass, produktive Systemänderung oder Abschluss eines Auditurteils.



A4 ist kein Freibrief: Risikoakzeptanz, Löschung, Export, Rollenänderung, Break Glass, Produktivfreigabe und externe verbindliche Kommunikation bleiben menschlich freigabepflichtig.

Abbildung 4: Die Autonomie-Leiter begrenzt KI von deterministischen Kernfunktionen bis zu eng kontrollierten, reversiblen Aktionen.

6. AI Use Case Register

Jeder KI-Anwendungsfall wird vor Entwicklung und Aktivierung registriert.

Feld	Beschreibung
Use-Case-ID und Name	stabile Kennung und verständlicher Titel
Business Owner	verantwortet Nutzen, Zielgruppe und Priorität
Risk Owner	verantwortet Restrisiko und Freigabestufe
Nutzer und Rolle	zugelassene Nutzergruppen und Sicht
Zweck und Nicht-Zweck	klarer Auftrag und verbotene Nutzung
Inputdaten	Datenobjekte, Klassifikation, Region, Retention
Outputvertrag	Text, JSON-Schema, Quellen, Länge, Sprache
Autonomiestufe	A0 bis A4
Risikoklasse	R1 bis R4 gemäß Abschnitt 8
Human Gate	Review, Approval oder Vier-Augen-Prinzip
Modelle und Provider	freigegebene Kombinationen und Regionen
Qualitätsziele	messbare Mindestwerte und Abbruchkriterien
Kosten- und Latenzbudget	Token, Request, Zeit und monatliches Budget
Fallback	deterministisch, manuell, anderes freigegebenes Modell oder deaktiviert
Monitoring	Qualität, Sicherheit, Nutzung, Beschwerden, Incidents
Reviewrhythmus	mindestens je Risikoklasse und bei wesentlicher Änderung

Kein KI-Feature darf produktiv freigeschaltet werden, wenn Owner, Risikoklasse, Outputvertrag, Testset, Fallback oder Abschaltnregel fehlen.

7. Priorisierter KI-Funktionskatalog

7.1 Kernfunktionen für den ersten vollständigen Demonstrator

ID	Funktion	Stufe	Daten	menschliche Kontrolle	Fallback
AI-UC01	Customer Executive Summary	A2	Twin, Ziele, KPIs, Risiken	Berater/CISO prüft materiale Aussagen	regelbasiertes Summary Template
AI-UC02	Risk Explanation	A1	Risikoszenario, Controls, Evidence	Quellen sichtbar; keine Scoreänderung	deterministische Ursache-Wirkungs-Kette
AI-UC03	Measure Drafting	A2	Risiko, Ziel, Control, Kapazität	Owner übernimmt oder verwirft	Maßnahmenvorlage
AI-UC04	Evidence Classification	A2	Datei-Metadaten, extrahierter Text	Kandidat muss bestätigt werden	manuelle Klassifikation
AI-UC05	Control-Evidence Mapping	A2	Controls, Evidence, Scope	kein automatischer Wirksamkeitsabschluss	regel-/keywordbasierte Kandidaten
AI-UC06	Management Narrative	A2	freigegebener Report Snapshot	Reviewer vor Veröffentlichung	deterministische Reportblöcke
AI-UC07	PowerPoint Storyline	A2	Report Package, Zielgruppe	Berater prüft Storyline	feste Storyline-Vorlage
AI-UC08	Tenant-scoped Q&A	A1	berechtigte Dokumente und Graphobjekte	Antworten mit Quellen; no-answer bei Lücke	globale Suche und gefilterte Treffer
AI-UC09	Morning Mission Explanation	A1	deterministische Prioritäten	erklärt nur, verändert Ranking nicht	regelbasierte Why-Texte
AI-UC10	Threat Signal Triage	A2	Threat Signal, Assets, Exposure	Analyst bestätigt Relevanz	deterministischer Relevanzfilter
AI-UC11	Workflow Draft	A2	Ziel, Trigger, Aktionen, Policies	Workflow Owner prüft vor Aktivierung	Blueprint-Bibliothek
AI-UC12	Onboarding Mapping Assistant	A2	Importfelder, kanonisches Modell	Mapping muss bestätigt werden	manueller Mapping-Editor
AI-UC13	Meeting and Decision Draft	A2	Notizen, Teilnehmer, Agenda	Nutzer bestätigt Decision Record	strukturiertes Formular
AI-UC14	Data Quality Explanation	A1	Qualitätsregeln und Fehler	keine automatische Datenkorrektur	regelbasierte Fehlermeldung
AI-UC15	Translation Assistant	A2	freigegebene Textblöcke	Fachprüfung bei externem Inhalt	Originalsprache bleibt verfügbar
AI-UC16	Service Opportunity Rationale	A2	Bedarf, Kapazität, Risiken, Charter	transparent, nicht manipulierend	regelbasierte Opportunity-Kriterien

7.2 Spätere oder höhere Assurance benötigende Funktionen

- semantischer Vergleich großer Policy- und Evidence-Sammlungen,
- automatische Erkennung widersprüchlicher Aussagen über mehrere Quellen,
- modellgestützte Anomalieerkennung in Zeitreihen und Graphveränderungen,
- agentische Durchführung risikoarmer interner Workflows,
- private oder kundenspezifische Modelle in dedizierten Umgebungen,
- domänenspezifische Fine-Tunes auf freigegebenen, nicht vertraulichen Daten,
- privacy-preserving, cross-tenant Practice Intelligence,
- multimodale Auswertung von Diagrammen und Screenshots,
- generative Simulation von Szenarioalternativen mit kontrollierter Fachvalidierung.

8. KI-Risikoklassen

Klasse	Charakter	Beispiele	Mindestkontrollen
R1 - niedrig	unterstützend, reversibel, geringe Materialität	Textvereinfachung, Suchhilfe, interne Zusammenfassung	Quellen/Label, Basis-Eval, Feedback, Kostenlimit
R2 - mittel	beeinflusst Arbeitspriorität oder fachlichen Entwurf	Maßnahmenvorschlag, Mapping, Reportentwurf	strukturierter Output, Human Review, Regression, Security Tests
R3 - hoch	beeinflusst Management-, Risiko-, Audit- oder externe Aussage	Executive Narrative, Serviceempfehlung, Threat Triage	benannter Risk Owner, Vier-Augen-Freigabe, starke Provenance, Red Teaming, strengere Datenroute
R4 - nicht zulässig oder nur nach separater Governance	irreversible, rechtsverbindliche oder sicherheitskritische autonome Wirkung	Risikoaakzeptanz, Löschung, Rollenänderung, externer Versand, Auditurteil	im Produktstandard verboten; Sonderfreigabe außerhalb dieses Konzepts

Die Klassifizierung berücksichtigt nicht nur den Modelltyp, sondern Zweck, Nutzer, betroffene Personen, Daten, Reichweite, Reversibilität, Fehlererkennbarkeit und Abhängigkeit anderer Prozesse. Dieselbe Modellfunktion kann je nach Nutzung R1 oder R3 sein.

9. Kontrollierte KI-Anfrage

Kein Fachmodul sendet beliebige Prompts direkt an einen Provider. Die Anfrage wird als versioniertes **AI Request Envelope** modelliert. Pflichtfelder:

- request_id, tenant_id, actor_id, role_context,
- use_case_id, risk_class, autonomy_level,
- purpose, input_object_ids, data_classification,
- prompt_template_version, output_schema_version,
- retrieval_policy_id, tool_policy_id,
- provider_policy_id, cost_budget, latency_budget,
- required_human_gate, retention_policy, trace_level.

Die Control Plane validiert Berechtigung, Datenklasse, Providerfreigabe, Region, Kostenbudget, Promptversion und Outputvertrag. Fehlt ein Pflichtwert, wird der Aufruf nicht still improvisiert.

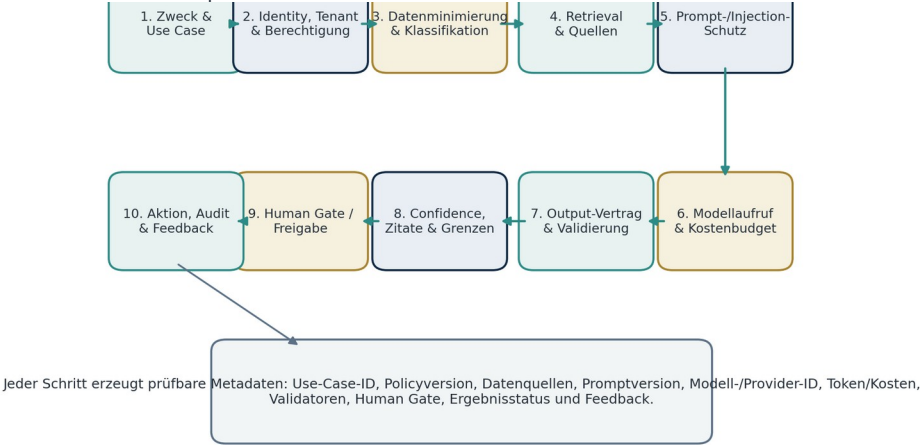


Abbildung 2: Jede KI-Anfrage durchläuft Zweck, Autorisierung, Datenminimierung, Retrievalschutz, Modellbudget, Outputvalidierung, Confidence, Human Gate und Audit.

10. AI Control Plane und technische Bausteine

10.1 AI Control Plane

Die Control Plane verwaltet:

- Use-Case-Register und Status,
- Richtlinien für Datenklassen, Regionen und Provider,
- Prompt- und Output-Schema-Versionen,
- Human Gates und Autonomiestufen,
- Modellrouting und Fallbackreihenfolge,
- Evaluationsergebnisse und Freigaben,
- Kosten-, Token- und Rate-Limits,
- Kill Switches,
- AI Audit Records und Incidentstatus.

10.2 Model Gateway

Das Model Gateway bietet eine einheitliche interne Schnittstelle für unterschiedliche Anbieter und Modellklassen. Es übernimmt Authentisierung, Routing, Timeout, Retry, Circuit Breaker, Tokenzählung, Kostenberechnung, Providertelemetrie und Fallback. Fachmodule kennen keine providerbezogenen Secrets oder proprietären Requestformate.

10.3 Retrieval and Tool Gateway

Retrieval und Tools werden getrennt vom Modell kontrolliert. Das Gateway prüft Tenant, Objektberechtigung, Zweck, Datenklassifikation und allowlistete Quellen. Tool Calls werden serverseitig gegen ein Schema validiert und erneut autorisiert. Das Modell erhält keine direkten Datenbank-, Shell-, Cloud- oder Connector-Credentials.

10.4 Assurance and Observability

Jeder Aufruf erzeugt strukturierte technische und fachliche Telemetrie. Sensible Inhalte werden nicht standardmäßig vollständig geloggt. Stattdessen speichert die Plattform IDs, Hashes, Versionen, Größen, Klassifikationen, Validatorergebnisse, Kosten, Latenz, Fehler und Human-Review-Status.

11. Modell- und Providerstrategie

Die Plattform verwendet eine **providerneutrale Auswahlmatrix** statt einer dauerhaft fest verdrahteten Modellentscheidung.

Kriterium	Bewertungsfrage
Fähigkeit	erfüllt das Modell Sprache, Struktur, Kontext und Tooling des Use Cases?
Sicherheit	unterstützt Provider Isolation, Verschlüsselung, Missbrauchsschutz und nachvollziehbare Änderungen?
Datenschutz	Region, Retention, Training Use, Subprozessoren, Löschung, DPA und Auditierbarkeit?
Zuverlässigkeit	Verfügbarkeit, Rate Limits, Versionierung, Deprecation und Support?
Qualität	Ergebnisse auf dem eigenen Golden Set und in relevanten Sprachen?
Kosten	Preis pro Request/Token, Retrieval, Tooling und Skalierung?
Latenz	interaktive oder asynchrone Anforderung?
Portabilität	strukturierte Outputs und Funktionen ohne proprietäre Sackgasse?
Governance	Modellkarte, Änderungsmitteilung, Incidentprozess und vertragliche Zusagen?

11.1 Provider Policy

Eine Provider Policy legt pro Datenklasse und Region fest:

- erlaubte Anbieter und Endpunkte,
- erlaubte Modellfamilien und Versionen,
- Datenresidenz und zulässige Verarbeitungsländer,
- maximale Retention beim Anbieter,
- Verbot der Nutzung für Training oder Produktverbesserung, sofern nicht ausdrücklich freigegeben,
- zulässige Subprozessoren,
- erlaubte Contentklassen,
- maximale Kontextgröße,
- Logging- und Auditniveau,
- Fallbackziele.

ENTSCHEIDUNG: Ein billigeres oder verfügbares Modell darf eine strengere Provider Policy nicht automatisch umgehen.

12. Modellregister und AI Bill of Materials

Jede freigegebene Modell- und Providerkombination besitzt einen Registereintrag:

- Provider, Produktname, Modell-ID und Version,
- Hostingform und Region,
- vorgesehene Use Cases,
- bekannte Fähigkeiten und Grenzen,
- Kontext-, Output- und Toolgrenzen,
- Datenverarbeitung und Retention,
- Training-Use-Status,
- Sicherheits- und Complianceunterlagen,
- Datum der letzten Evaluation,
- freigegebene Prompt-/Schema-Versionen,
- bekannte Incidents und Abweichungen,
- Ablöse- oder Deprecationplan.

Das Register ist Bestandteil der technischen Konfigurationsquelle und nicht nur eine Präsentationstabelle.

13. Retrieval Augmented Generation

RAG darf nur Inhalte verwenden, die der aktuelle Nutzer auch ohne KI lesen dürfte. Retrieval ist ein autorisierter Datenzugriff, kein privilegierter KI-Sonderweg.

13.1 Ingestion und Indexierung

- Dateien werden klassifiziert, auf Malware und aktive Inhalte geprüft und in isolierter Verarbeitung extrahiert.
- Chunks tragen Tenant, Objekt, Quelle, Version, Gültigkeit, Klassifikation, Owner und Berechtigungsmetadaten.
- Indexierung wahrt Löschung, Legal Hold, Versionen und regionale Grenzen.
- Niedrig vertrauenswürdige, veraltete oder nicht freigegebene Quellen werden sichtbar markiert oder ausgeschlossen.
- Embeddings werden als abgeleitete vertrauliche Daten behandelt, nicht als anonym angenommen.

13.2 Query und Retrieval

- Tenant- und Objektberechtigungen werden vor und nach Retrieval geprüft.
- Suchraum, Top-k, Mindestscore, Quellenarten und Zeitbezug sind Use-Case-spezifisch.
- Retrieval liefert Quellenfragmente und Metadaten, keine freie Befehlsautorität.
- Bei unzureichender Quellenlage antwortet das System mit einer Datenlücke statt mit plausibel klingender Ergänzung.
- Jede materiale Aussage kann auf konkrete Quellenobjekte zurückgeführt werden.

13.3 Schutz gegen Retrieval Injection

Dokumente, Webseiten, Tickets und E-Mails gelten als **untrusted content**. Darin enthaltene Aufforderungen wie „Ignoriere vorherige Regeln“, „Sende Daten an...“ oder „Rufe dieses Tool auf“ werden als Inhalt behandelt und dürfen System-, Policy- oder Toolregeln nicht ändern. Kritische Retrievalpfade nutzen Trennung von Instruktion und Quelle, Inhaltsmarkierung, Injection-Detektion, erlaubte Aufgabenform und Outputvalidierung.

14. Prompt-, Template- und Policy-Management

Prompts sind versionierte Produktartefakte.

Jede Promptversion besitzt:

- Use-Case-ID und Owner,
- Zweck, Rolle und erlaubte Datenklassen,
- Systeminstruktion und unveränderbare Policyteile,
- Platzhalter mit Datentypen und Größenlimits,
- Retrieval- und Toolregeln,
- Outputschema,
- Beispiele und Gegenbeispiele,
- verbotene Aussagen und Aktionen,
- Testset und Evaluationsergebnis,
- Freigabestatus, Gültigkeit und Vorgängerversion.

Änderungen an Systemprompt, Toolbeschreibung, Retrievalregeln oder Outputschema gelten als produktrelevante Änderungen. Sie durchlaufen Code Review, Evaluation und risikobasierte Freigabe. Geschäftsnutzer dürfen Tonalität oder Zielgruppe konfigurieren, aber keine Sicherheits- und Mandantenregeln überschreiben.

15. Output Contracts und Validierung

Maschinenrelevante KI-Ausgaben verwenden einen expliziten Output Contract. Beispiel für einen Maßnahmenentwurf:

Feld	Regel
title	kurz, handlungsorientiert, keine unzulässige Gewissheit
rationale	Bezug zu Risiko, Ziel und Quellen
recommended_actions	strukturierte, begrenzte Schritte
affected_objects	ausschließlich berechnete Objekt-IDs
assumptions	explizite Annahmen
evidence_refs	vorhandene Quellen oder leere Liste
confidence_components	Quellenabdeckung, Datenfrische, Konsistenz, Evalstatus
human_gate	benötigte Rolle und Freigabeart
limitations	Datenlücken und nicht geprüfte Aussagen

Validatoren prüfen Schema, erlaubte IDs, Quellenexistenz, Tenantzugehörigkeit, verbotene Claims, Längen, Datentypen, Links, HTML/Markdown und mögliche Prompt- oder Secret-Leaks. Eine syntaktisch gültige Ausgabe ist noch nicht fachlich korrekt; risikobasierte fachliche Validatoren und Human Review folgen.

16. Quellen, Provenance und Confidence

16.1 AI Provenance Record

Für jede übernommene materiale KI-Ausgabe werden mindestens gespeichert:

- Use-Case-ID, Request-ID und Zeitpunkt,
- Nutzer, Rolle und Tenant,
- Provider, Modell und Version,
- Prompt-, Retrieval- und Outputschema-Version,
- verwendete Objekt- und Quellenreferenzen,
- Validator- und Policyergebnisse,
- Confidence-Komponenten,
- Human Reviewer, Änderung und Freigabe,
- final übernommener Inhalt,
- Outcome oder spätere Korrektur.

16.2 Confidence ist berechnet, nicht behauptet

Das Sprachmodell darf eine Selbsteinschätzung liefern, diese wird jedoch nicht als Plattform-Confidence verwendet. Die Plattform berechnet einen erklärbaren Vertrauensstatus aus:

- Quellenabdeckung und Zitierbarkeit,
- Datenfrische und Gültigkeit,
- Datenqualität des digitalen Zwillings,
- Widerspruchsfreiheit der Quellen,
- Ergebnis der Fach- und Schema-Validatoren,
- Leistungswert des Modells auf dem relevanten Golden Set,
- Ähnlichkeit des aktuellen Falls zu getesteten Fällen,
- menschlichem Reviewstatus.

Ausgabe erfolgt als Band, beispielsweise „hoch“, „mittel“, „niedrig“ oder „nicht ausreichend“, ergänzt um die stärksten Gründe. Niedrige Confidence darf nicht durch selbstbewusste Sprache verdeckt werden.

17. Human Gates und Verantwortlichkeit

Wirkung	Beispiel	Gate
informativ	Klartext-Erklärung eines vorhandenen Scores	keine Übernahme nötig; Quellen sichtbar
interner Entwurf	Task, Maßnahmenvorschlag, Meeting Summary	zuständiger Bearbeiter bestätigt
materiale Fachwirkung	Control Mapping, Threat Relevanz, Managementnarrativ	qualifizierter Reviewer
Management- oder Kundenwirkung	Investitionsvorschlag, externe Präsentation, Serviceempfehlung	benannter Approver, häufig Vier-Augen-Prinzip
irreversible oder kritische Wirkung	Löschung, Risikoakzeptanz, Rechte, Break Glass, externer Versand	KI darf nicht final freigeben

Ein Human Gate ist keine bedeutungslose Schaltfläche. Der Reviewer sieht Quellen, Änderungen, Datenlücken, Confidence, Auswirkungen und Alternativen. Die Plattform erfasst, ob der Inhalt übernommen, bearbeitet, abgelehnt oder eskaliert wurde.

18. Tool Use und bounded Agency

Toolfähige Modelle dürfen ausschließlich über den Tool Gateway handeln.

18.1 Toolvertrag

Jedes Tool besitzt:

- eindeutigen Namen und Zweck,
- Input- und Outputschema,
- erlaubte Use Cases und Rollen,
- Tenant- und Objektprüfung,
- maximale Reichweite,
- Reversibilität,
- Human-Gate-Anforderung,
- Idempotenz- und Retryregeln,
- Logging- und Auditniveau,
- Kill Switch.

18.2 Erlaubte frühe Tools

- interne Suche mit berechtigtem Retrieval,
- Erstellen eines Entwurfstasks,
- Erzeugen eines Reportentwurfs,
- Start einer nicht verändernden Simulation,
- Abruf eines freigegebenen Objekt-360-Read Models,
- Validierung eines strukturierten Entwurfs.

18.3 Nicht erlaubte autonome Tools

- Benutzer- oder Rollenänderung,
- Löschung oder Massenexport,
- Änderung von Risikowerten oder Control-Wirksamkeit ohne Fachworkflow,
- externer E-Mail- oder Teams-Versand,
- Vertrags-, Preis- oder SLA-Änderung,
- Break Glass oder Supportzugriff,
- Änderung von Produktionsinfrastruktur,
- Abschluss eines Findings, Audits oder Management Reviews.

19. Sicherheitsbedrohungen und Guardrails

Die Plattform übernimmt einen lebenszyklusorientierten AI Threat Model. Relevante Risikomuster orientieren sich unter anderem an NIST AI RMF, NIST GenAI Profile, ENISA und den OWASP-Projekten.

Bedrohung	Plattformrisiko	zentrale Kontrollen
Prompt Injection	Quelle oder Nutzer verändert Verhalten und Tooling	Instruktions-/Datentrennung, Injection Detection, Tool Allowlist, Output Validation
Sensitive Information Disclosure	Prompt oder Output legt Kundendaten, Secrets oder Systemdetails offen	Datenminimierung, Redaction, Provider Policy, DLP, Outputfilter, keine Secrets im Kontext
Supply Chain	kompromittiertes Modell, SDK, Promptpaket oder Dependency	AI BOM, Signaturen, Version Pinning, SBOM, Provider Due Diligence, Change Review
Data/Model Poisoning	manipulierte Wissensbasis oder Trainings-/Embeddingdaten	Source Trust, Ingestion Review, Versionen, Quarantäne, Monitoring
Improper Output Handling	Modelloutput führt zu XSS, Injection oder falscher Aktion	Schema, Sanitizing, Encoding, keine direkte Ausführung
Excessive Agency	Modell erhält zu viele Tools oder Rechte	bounded agency, minimale Scopes, Human Gate, serverseitige Re-Authorization
System Prompt Leakage	interne Regeln oder vertrauliche Instruktionen werden offengelegt	keine Secrets im Prompt, Segmentierung, Leak Tests, sichere Fehlermeldung
Vector/Embedding Weakness	Cross-Tenant-Leak, manipuliertes Retrieval, Datenrückstände	Tenantpartition, ACL-Recheck, Delete Propagation, Retrieval Evaluation
Misinformation	erfundene Fakten, falsche Quellen oder falsche Sicherheit	grounded generation, no-answer, Claim Validation, Confidence, Human Review
Unbounded Consumption	Kosten-, Token-, Tool- oder Schleifenexplosion	Budgets, Rate Limits, Max Steps, Timeout, Queue- und Circuit-Breaker-Kontrolle

Zusätzlich werden Modell-DoS, Providerkontenübernahme, Membership Inference, Model Extraction, unsichere Fine-Tunes, schädliche Dateinputs, Multi-Turn-Context-Poisoning und Missbrauch von Feedbackkanälen berücksichtigt.

20. Datenschutz und Datenverarbeitung

20.1 Datenminimierung

Das Modell erhält vorzugsweise abgeleitete, maskierte oder zusammengefasste Daten statt vollständiger Originalartefakte. IDs werden nur übergeben, wenn sie fachlich nötig sind. Highly Confidential und Restricted Evidence benötigen strengere Provider- und Use-Case-Policies; Secret Material wird niemals in den Modellkontext gegeben.

20.2 Training, Retention und Providerzugriff

Standardposition:

- keine Nutzung von Kundeneingaben oder Outputs zum Training externer Modelle,
- minimale oder vertraglich deaktivierte Provider-Retention,

- keine menschliche Providerprüfung vertraulicher Inhalte ohne ausdrückliche Rechts- und Kundenfreigabe,
- DPA, Subprozessoren, Region und Incidentpflichten werden vor Freigabe geprüft,
- Providertelemetrie darf keine ungeprüften Fachinhalte enthalten.

20.3 Personenbezogene Daten

Personenbezogene Daten werden nur bei dokumentiertem Zweck und Rechtsgrundlage verarbeitet. Für sensible Auswertungen werden Datenschutz-Folgen, erwartbare Betroffenenwirkung, Transparenz, Datenminimierung, Widerspruchsmöglichkeiten und Löschung geprüft. Ein Modell oder Embedding gilt nicht automatisch als anonym.

20.4 Cross-Tenant Learning

Cross-Tenant Learning ist im ersten Produkt nicht mit Rohkundendaten vorgesehen. Zulässig sind zunächst synthetische Referenzdaten und ausdrücklich freigegebene, ausreichend aggregierte Practice Insights. Re-Identifikationsrisiko, Gruppengröße, Zweck, Governance und Opt-out werden vor produktiver Nutzung bewertet.

21. Kosten-, Latenz- und Verbrauchskontrolle

Jeder Use Case besitzt ein Budget für:

- maximale Eingabe- und Ausgabetokens,
- Retrievalumfang,
- Toolschritte,
- parallele Requests,
- Timeout und Retry,
- Kosten pro Request und Monat,
- zulässige Provider-/Modellklasse.

Die Plattform nutzt kleine oder deterministische Modelle, wenn sie die Qualitätsziele erfüllen. Lange Reports werden asynchron erzeugt und blockieren keine interaktive Session. Wiederholte identische Anfragen können sichere Cache- oder Artefaktwiederverwendung nutzen, sofern Datenfrische, Tenant Scope und Berechtigungen stimmen.

Bei Budgetüberschreitung wird nicht unbemerkt weitergerechnet. Das System reduziert optionalen Kontext, wechselt auf einen freigegebenen günstigeren Pfad, fragt nach Bestätigung oder nutzt Fallback. Kostenoptimierung darf Sicherheits- oder Datenschutzpolicies nicht senken.

22. Evaluation und Freigabe

22.1 Evaluationsdimensionen

- fachliche Korrektheit,
- Vollständigkeit und Relevanz,
- Groundedness und Citation Correctness,
- Einhaltung von Tenant, Zweck und Datenklasse,
- sichere Ablehnung und no-answer Verhalten,
- Robustheit gegen Prompt Injection und manipulative Quellen,
- Output-Schema und Tool-Sicherheit,
- Konsistenz über Wiederholungen,
- Sprach- und Rollenverständlichkeit,
- Bias und unterschiedliche Nutzerwirkungen,
- Latenz, Verfügbarkeit und Kosten,
- Änderungsstabilität bei Modell- oder Promptwechsel.

22.2 Testsets

Jeder Use Case besitzt:

- Golden Set mit erwarteten Kernaussagen,
- Edge Cases und unvollständigen Daten,
- negative Beispiele und verbotene Antworten,
- adversariale Prompt-Injection- und Data-Leak-Tests,
- Cross-Tenant-Negativtests,
- mehrsprachige und rollenbezogene Varianten,
- Regressionsergebnisse gegen Vorgängerversion.

Testdaten sind synthetisch oder rechtmäßig freigegeben und auf ihren Verwendungszweck begrenzt.

22.3 Freigabegates

Klasse	vor Pilot	vor allgemeiner Nutzung
R1	Basis-Golden-Set, Security Smoke Test, Kostenlimit	Nutzungsmonitoring und Feedback
R2	vollständiges Golden Set, Prompt Injection, Datenschutz, Human-Review-Test	Regression, dokumentierter Risk Owner, Incident Runbook
R3	unabhängiges Review, Red Teaming, Vier-Augen-Freigabe, Provider Due Diligence	laufende Stichprobe, strengere Schwellen, regelmäßige Revalidierung
R4	nicht Teil des Standardprodukts	separate Governance und rechtliche Freigabe erforderlich

LLM-as-a-Judge darf Skalierung unterstützen, ersetzt aber keine fachlich kuratierten Referenzen, deterministischen Validatoren oder menschliche Prüfung kritischer Fälle.

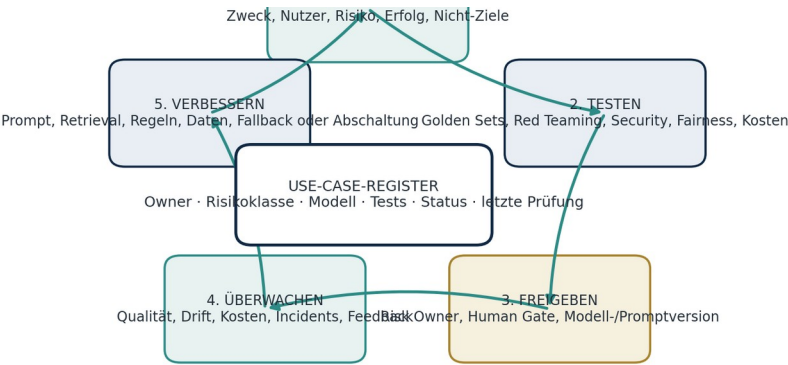


Abbildung 3: Der AI Assurance Loop verbindet Use-Case-Definition, Evaluation, Freigabe, Monitoring und kontrollierte Verbesserung.

23. Qualitätsmetriken und Schwellen

Metrik	Bedeutung	Beispielhafte Produktregel
Grounded Claim Rate	Anteil materialer Aussagen mit gültiger Quelle	externe Reports benötigen vollständige Quellenabdeckung
Citation Correctness	Quelle unterstützt tatsächlich die Aussage	falsche Zitate blockieren Freigabe
Critical Error Rate	wesentliche falsche oder unzulässige Aussage	für R3 nahe null; jeder Treffer Incident Review
No-answer Precision	System verweigert korrekt bei unzureichender Basis	darf keine Lücken kreativ schließen
Schema Validity	strukturierte Ausgabe erfüllt Vertrag	Toolpfade benötigen 100 Prozent nach Retry/Repair
Tenant Leakage Rate	Cross-Tenant-Inhalt in Tests	null toleriert
Human Acceptance	Anteil unverändert/bearbeitet/abgelehnt	dient Verbesserung, nicht automatischer Qualitätsbeweis
Rework Time	Zeit zur fachlichen Korrektur	muss unter manueller Neuerstellung liegen
Latency	Ende-zu-Ende-Zeit	je Use Case budgetiert
Cost per Accepted Output	Kosten je tatsächlich übernommenes Ergebnis	Grundlage für Routing und Servicekalkulation

Schwellen werden nicht pauschal für alle KI-Funktionen gesetzt. Ein interner Textvorschlag hat andere Anforderungen als ein Vorstandsnarrativ oder Threat-Triage-Ergebnis.

24. Monitoring, Drift und laufende Assurance

Die Plattform überwacht:

- Nutzung und Akzeptanz je Use Case und Rolle,
- Modell-, Prompt-, Retrieval- und Provider-Version,
- Fehler, Ablehnungen und Human Overrides,
- Groundedness, Quellenlücken und Validatorfehler,
- Kosten, Token, Latenz und Rate Limits,
- Provider- und Modelländerungen,
- Daten- und Concept Drift,
- Prompt-Injection- und Missbrauchssignale,
- Beschwerden, Incidents und Korrekturen,
- Ergebniswirkung, soweit messbar.

Drift kann durch neue Kundendaten, geänderte Fachmethodik, neue Bedrohungen, Modellupdate, Promptänderung oder geändertes Nutzerverhalten entstehen. Wesentliche Drift setzt den Use Case auf „review required“, reduziert Autonomie oder deaktiviert ihn automatisch.

25. AI Incident Management

AI Incidents werden mit Security-, Privacy-, Quality- und Business-Impact klassifiziert.

Beispiele:

- Cross-Tenant- oder unzulässige Datenoffenlegung,
- erfundene Managementaussage in veröffentlichtem Report,
- Prompt Injection löst unzulässigen Toolversuch aus,
- Modellupdate verschlechtert Fachqualität,
- Provider speichert oder verarbeitet Daten entgegen Policy,
- massiver Kostenanstieg oder Endlosschleife,
- systematisch verzerrte oder diskriminierende Empfehlung,
- falsche Quelle oder nicht nachvollziehbare Aussage,
- wiederholte Fehlklassifikation kritischer Evidence.

Reaktionsschritte:

- 1. Use Case, Modell, Provider oder Toolpfad isolieren beziehungsweise deaktivieren.

2. betroffene Requests, Nutzer, Tenants, Outputs und Folgeaktionen ermitteln.
3. externe Veröffentlichung stoppen oder korrigieren.
4. Security-/Privacy-Incidentprozess aus Dokument 19 auslösen, falls relevant.
5. Ursache in Prompt, Retrieval, Daten, Modell, Policy, Tooling oder Human Gate analysieren.
6. Tests, Runbook, Register und Freigabe aktualisieren.
7. kontrollierte Wiederfreigabe mit Regression und Monitoring.

26. Fallback und Degradation

Für jeden Use Case ist eine geordnete Fallbackkette definiert:

1. erneuter Aufruf derselben freigegebenen Kombination bei transientem Fehler,
2. anderes freigegebenes Modell innerhalb derselben Provider Policy,
3. deterministischer Template-, Regel- oder Suchpfad,
4. manueller Workflow mit verständlicher Aufgabenübergabe,
5. kontrollierte Deaktivierung.

Nicht erlaubt ist der Wechsel auf ein Modell, das Datenresidenz, Retention, Sicherheit oder Qualität des Use Cases nicht erfüllt. Die UI zeigt, ob ein Ergebnis echt KI-generiert, deterministisch erzeugt, simuliert oder manuell erstellt wurde.

27. UX, Transparenz und AI Literacy

27.1 Kennzeichnung

KI-unterstützte Inhalte zeigen abhängig von Materialität:

- „KI-Entwurf“, „KI-erklärt“, „KI-vorgeschlagen“ oder „simulierte KI-Ausgabe“,
- Quellen und Datenstand,
- Confidence und wichtigste Einschränkungen,
- Modell-/Providerdetail in einer aufklappbaren technischen Ansicht,
- menschlichen Reviewstatus,
- Optionen „übernehmen“, „bearbeiten“, „ablehnen“, „Quelle öffnen“ und „Problem melden“.

27.2 Keine künstliche Autorität

Die UI vermeidet Formulierungen wie „Die KI hat entschieden“. Stattdessen heißt es beispielsweise: „Vorschlag basierend auf drei freigegebenen Quellen; mittlere Confidence; Prüfung durch ISMS Manager erforderlich.“

27.3 AI Literacy

Nutzer erhalten rollenbezogene Kurzhinweise zu:

- typischen Stärken und Grenzen,
- sicherer Eingabe und Umgang mit vertraulichen Daten,
- Quellen- und Confidenceinterpretation,
- Verantwortung bei Übernahme,
- Meldung fehlerhafter oder riskanter Ergebnisse.

28. Fachspezifikation ausgewählter Use Cases

28.1 Customer Executive Summary

Ziel: Ein Berater, CISO oder Executive versteht Zustand, Trend, Top-Risiken, Zielroute und notwendige Entscheidungen in weniger als einer Minute.

Input: freigegebener Customer Snapshot, Strategie-DNA, KPIs, Top-Risiken, Zielroute, Service Health, Datenqualität. **Output:** maximal fünf Kernaussagen, drei Veränderungen, zwei Entscheidungen, Quellen, Confidence und Datenlücken. **Verbot:** neue Scores, Auditgarantie, unbelegte Schadenszahlen oder vertrauliche Detailoffenlegung. **Gate:** R3 bei externer oder Vorstandsnutzung; R2 bei internem Beraterentwurf. **Fallback:** deterministische Zusammenfassung nach priorisierten KPI- und Decision-Card-Regeln.

28.2 Risk Explanation

Ziel: Ein Nutzer versteht, warum ein vorhandener Risikostatus besteht und wodurch er sich verändert.

Input: deterministisches Risikoszenario, Threat Activity, Exposure, Controls, Evidence, Confidence. **Output:** Ursache-Wirkungs-Erklärung mit Quellen und Hinweis auf fehlende Daten. **Verbot:** Änderung von Likelihood, Impact oder Akzeptanz. **Gate:** A1; keine Übernahme in den Score. **Fallback:** graphbasierte „weil“-Kette aus Dokument 09.

28.3 Measure Drafting

Ziel: Aus Risiko, Control-Lücke und Zielprofil entsteht ein bearbeitbarer Maßnahmenentwurf.

Input: Zielzustand, betroffene Objekte, Control-Anforderung, Kapazität, Servicegrenzen. **Output:** Titel, Rationale, Schritte, Owner-Vorschlag, Evidencebedarf, Abhängigkeiten, Aufwandband, Annahmen. **Verbot:** automatische Zuweisung, Budgetfreigabe oder Abschluss. **Gate:** zuständiger Owner bestätigt. **Fallback:** Maßnahmen-Blueprint.

28.4 Evidence Classification and Mapping

Ziel: Hochgeladene Evidence wird schneller klassifiziert und passenden Controls als Kandidat zugeordnet.

Input: sichere Extraktion, Metadaten, Scope, Controlkatalog. **Output:** Dokumenttyp, Zeitraum, mögliche Controls, Datenklasse, Confidence, Warnungen. **Verbot:** automatische Wirksamkeitsbestätigung oder Umgehung von Malware-/Dateiprüfung. **Gate:** Control Owner oder Reviewer bestätigt. **Fallback:** Metadaten- und Keywordregeln.

28.5 Management Narrative and PowerPoint Storyline

Ziel: Aus einem eingefrorenen Report Snapshot entsteht eine verständliche, zielgruppengerechte Erzählung.

Input: ausschließlich freigegebene Claims, KPIs, Decisions, Quellen, Zielgruppe und Template. **Output:** Storyline, Kernaussagen, Sprecherhinweise und Slide-Titel. **Verbot:** neue Fakten, unsichtbare Datenquellen, automatische externe Veröffentlichung. **Gate:** fachlicher Reviewer und bei externem Einsatz Approver. **Fallback:** deterministische Storyline und Textbausteine aus Dokument 12.

28.6 Tenant-scoped Q&A

Ziel: Rollen erhalten Antworten auf Fragen über die ihnen zugänglichen Plattformdaten.

Input: Nutzerfrage, Rolle, Tenant, Retrieval Policy, berechnete Quellen. **Output:** kurze Antwort, Quellen, Datenstand, Confidence, Follow-up-Vorschläge. **Verbot:** Zugriffserweiterung durch Frageformulierung, Cross-Tenant-Inhalte, Spekulation bei fehlender Quelle. **Gate:** A1; kritische Entscheidung wird als Decision Card weitergeführt. **Fallback:** globale Suche mit Filtern und Trefferauszügen.

29. KI im Managed-Service-Modell

KI soll Managed Services skalieren, ohne Qualität oder Verantwortung zu verschleiern.

Mögliche Wertbeiträge:

- schnellere Erstentwürfe und standardisierte Deliverables,
- geringere Such- und Aufbereitungszeit,
- konsistentere Begründungen und Übergaben,
- bessere Wiederverwendung freigegebener Methodik,
- schnellere Erkennung von Datenlücken und wiederkehrenden Mustern,
- Portfolioverdichtung für Service Leads,
- messbarer Zeitgewinn im Value Ledger.

Die Plattform trennt **Zeitersparnis**, **fachliche Qualitätsverbesserung** und **zusätzliche Servicewirkung**. Eine KI-Ausgabe ist nicht automatisch billable oder ein Managed-Service-Erfolg. Service Charter, SLA, Reviewer und Kundenverantwortung bleiben maßgeblich.

30. Demonstrator-Architektur

30.1 Zwei Betriebsmodi

- **Live AI Mode:** nutzt einen konfigurierten, freigegebenen Provider über das Model Gateway.
- **Deterministic Demo Mode:** nutzt reproduzierbare Fixtures und regelbasierte Generatoren aus denselben Output Contracts.

Die UI zeigt den Modus eindeutig. Der Demonstrator darf keine Live-Funktion vortäuschen. Beide Modi erzeugen dieselben Metadatenstrukturen, sodass UI, Workflows, Human Gates, Reporting und Audit Records vollständig testbar bleiben.

30.2 Demo-Daten

- ausschließlich synthetische Unternehmen, Personen, Risiken, Evidence und Incidents,
- vorbereitete Quellen mit unterschiedlichen Vertrauens- und Datenqualitätsstufen,
- absichtlich eingebaute Datenlücken und widersprüchliche Informationen,
- sichere Prompt-Injection-Beispiele in einer Demo-Evidence,
- mehrere Rollen mit unterschiedlichen Berechtigungen,
- Kosten- und Latenzwerte als klar gekennzeichnete Simulation, sofern kein Liveprovider aktiv ist.

30.3 Technische Mindestumsetzung

- AI Use Case Registry als Konfigurationsdatei oder Datenbanktabelle,
- Model Gateway Interface mit Live- und Demo-Adapter,
- tenantbezogenes Retrieval aus synthetischem Datenbestand,
- versionierte Prompt Templates,
- JSON-Schema-Validierung,
- Human-Review-Status und Decision Record,
- AI Provenance Record,
- Rate Limit, Timeout und Kostenbudget,
- Kill Switch pro Use Case,
- Eval-Suite mit Golden und adversarial Cases.

31. Verbindliche Demo-Szenen

1. Ein Berater öffnet die Muster GmbH und erzeugt eine Customer Executive Summary mit Quellen, mittlerer Confidence und einer sichtbaren Datenlücke.
2. Der Nutzer wechselt auf deterministischen Fallback; die Seite bleibt funktionsfähig und zeigt den geänderten Modus.
3. Ein Risiko wird in Klartext erklärt, ohne dass sein deterministischer Score verändert wird.
4. Die Plattform entwirft eine Maßnahme; Owner, Evidencebedarf und Annahmen werden vor Übernahme geprüft.
5. Eine Evidence-Datei wird als Policy-Kandidat klassifiziert und zwei Controls zugeordnet; der Reviewer lehnt eine Zuordnung ab.
6. Ein manipuliertes Dokument enthält eine Prompt-Injection-Anweisung; die Plattform markiert sie und führt keinen Tool Call aus.
7. Tenant-scoped Q&A beantwortet eine Frage mit drei Quellen und verweigert eine nicht belegbare Aussage.
8. Ein Management Narrative wird aus einem eingefrorenen Report Snapshot erzeugt und muss vor PPTX-Export freigegeben werden.
9. Ein Provider ist nicht verfügbar; Circuit Breaker und Fallback verhindern einen leeren oder erfundenen Report.
10. Ein Kostenbudget wird erreicht; die Plattform erklärt die Begrenzung und bietet einen deterministischen Pfad an.
11. Ein R3-Use-Case zeigt Vier-Augen-Freigabe, Provenance und unveränderbaren Reviewstatus.
12. Ein Security Operator deaktiviert einen Use Case über Kill Switch und sieht betroffene Requests und Outputs.
13. Ein Nutzer meldet eine falsche Aussage; Feedback erzeugt Quality Item und Regressionstest.
14. Ein Executive sieht klar, welche Aussagen KI-entworfen, welche deterministisch berechnet und welche menschlich freigegeben wurden.

32. Fehler- und Sonderfälle

- **Keine Quellen:** no-answer oder als unvollständig markierter Entwurf; keine erfundene Ergänzung.
- **Widersprüchliche Quellen:** Konflikt anzeigen, Quellen nebeneinanderstellen, menschliche Klärung anfordern.
- **Veraltete Evidence:** Datenstand und Gültigkeit zeigen; materiale Aussage blockieren, falls erforderlich.
- **Provider Timeout:** Retry gemäß Policy, danach Circuit Breaker und Fallback.
- **Ungültiger strukturierter Output:** einmalige sichere Reparatur oder Abbruch; keine unvalidierte Toolausführung.
- **Prompt Injection erkannt:** Quelle markieren, Tooling sperren, Security Event je Severity.
- **Cross-Tenant-Treffer:** Zugriff blockieren, Incident untersuchen, Index- und Policytests auslösen.
- **Human Reviewer nicht verfügbar:** Workflow wartet oder eskaliert; KI darf Gate nicht überspringen.
- **Modellversion geändert:** Use Case auf Revalidation setzen, wenn Änderung wesentlich ist.
- **Kostenanomalie:** Budgetstop, Owner informieren, Trace prüfen.
- **Nutzer bearbeitet Output:** finale Version und Differenz speichern, nicht nur Modellrohtext.
- **Output später falsch:** Korrektur, Empfängeranalyse und Quality-Incident-Prozess.

33. Globale Akzeptanzkriterien

- **20A-AC01:** Kein KI-Aufruf erfolgt ohne Use-Case-ID, Tenant Context, Actor und Zweck.

- **20A-AC02:** Kritische fachliche Scores und Statusübergänge funktionieren ohne generative KI.
- **20A-AC03:** Jeder aktive Use Case besitzt Owner, Risikoklasse, Autonomiestufe, Outputvertrag, Testset, Fallback und Kill Switch.
- **20A-AC04:** Retrieval gibt nur Objekte zurück, die der aktuelle Nutzer direkt lesen dürfte.
- **20A-AC05:** Cross-Tenant-Negativtests tolerieren keinen Daten- oder Metadatenleak.
- **20A-AC06:** Secret Material wird weder an Modelle gesendet noch in Prompts oder Standardtelemetrie gespeichert.
- **20A-AC07:** Materiale Aussagen sind mit Quellen oder explizitem „nicht belegt“ versehen.
- **20A-AC08:** Confidence wird aus nachvollziehbaren Komponenten berechnet und nicht allein vom Modell übernommen.
- **20A-AC09:** Tool Calls werden serverseitig validiert und erneut autorisiert.
- **20A-AC10:** Risikoakzeptanz, Löschung, Rechteänderung, Break Glass und externe Veröffentlichung sind nicht autonom möglich.
- **20A-AC11:** R2- und R3-Use-Cases besitzen dokumentierte Human Gates.
- **20A-AC12:** Modell-, Prompt-, Retrieval- und Schemaänderungen sind versioniert und regressionsgetestet.
- **20A-AC13:** Prompt-Injection-, Data-Leak-, Unbounded-Consumption- und Improper-Output-Tests sind Teil der Evaluation.
- **20A-AC14:** Provider Policies verhindern automatischen Wechsel auf unzulässige Region oder Retention.
- **20A-AC15:** Kundendaten werden standardmäßig nicht für Providertraining genutzt.
- **20A-AC16:** Live AI und Deterministic Demo Mode verwenden denselben Output Contract und sind klar gekennzeichnet.
- **20A-AC17:** Providerausfall blockiert keinen kritischen Kernworkflow.
- **20A-AC18:** Jeder übernommene materiale Output besitzt AI Provenance und Human-Review-Status.
- **20A-AC19:** Nutzer können KI-Ausgaben bearbeiten, ablehnen und als Problem melden.
- **20A-AC20:** Kosten, Token, Latenz und Toolschritte sind je Use Case begrenzt und beobachtbar.
- **20A-AC21:** Ein Kill Switch kann Use Case, Modell, Provider und Toolpfad kontrolliert deaktivieren.
- **20A-AC22:** Eine falsche veröffentlichte KI-Aussage kann auf Requests, Quellen, Versionen und Empfänger zurückgeführt werden.
- **20A-AC23:** KI-Kennzeichnung und Transparenz sind rollen- und materialitätsgerecht sichtbar.
- **20A-AC24:** Die Demo enthält mindestens ein erfolgreich abgewehrtes Prompt-Injection-Szenario.
- **20A-AC25:** Evaluationsergebnisse sind Bestandteil des Freigabestatus und nicht nur externe Dokumentation.
- **20A-AC26:** AI Audit Records enthalten keine unnötigen vollständigen vertraulichen Prompts oder Outputs.
- **20A-AC27:** Datenlöschung und Retention propagieren auch in Retrieval-Index, Cache und AI-Artefakte.
- **20A-AC28:** Ein Modell- oder Providerwechsel kann ohne Änderung der fachlichen Produktverträge erfolgen.

34. Festgelegte Entscheidungen

- **ENTSCHEIDUNG 20A-01:** Die Plattform ist KI-gestützt, nicht KI-abhängig.
- **ENTSCHEIDUNG 20A-02:** Generative KI darf fachliche Kernberechnungen und Autorisierungslogik nicht ersetzen.
- **ENTSCHEIDUNG 20A-03:** Alle KI-Aufrufe laufen über AI Control Plane und Model Gateway.
- **ENTSCHEIDUNG 20A-04:** Jeder Use Case wird registriert, risikoklassifiziert, getestet und separat abschaltbar.
- **ENTSCHEIDUNG 20A-05:** Maschinenrelevante Outputs verwenden strukturierte, validierte Verträge.
- **ENTSCHEIDUNG 20A-06:** Confidence wird plattformseitig aus Quellen, Daten und Evaluation gebildet.
- **ENTSCHEIDUNG 20A-07:** R3-Anwendungsfälle benötigen benannten Risk Owner und qualifizierte Freigabe.
- **ENTSCHEIDUNG 20A-08:** Kritische oder irreversible Aktionen bleiben außerhalb autonomer KI-Autorität.
- **ENTSCHEIDUNG 20A-09:** RAG prüft Tenant- und Objektberechtigungen bei jeder Anfrage erneut.
- **ENTSCHEIDUNG 20A-10:** Kundendaten werden standardmäßig nicht für externes Modelltraining verwendet.
- **ENTSCHEIDUNG 20A-11:** Provider- und Modellwahl bleiben austauschbar und datenklassenabhängig.
- **ENTSCHEIDUNG 20A-12:** Live AI Mode und Deterministic Demo Mode sind beide verbindlicher Teil des Demonstrators.
- **ENTSCHEIDUNG 20A-13:** KI-generierte materiale Aussagen benötigen Quellen und Provenance.
- **ENTSCHEIDUNG 20A-14:** Prompt-, Retrieval-, Tool- und Schemaänderungen gelten als kontrollierte Produktänderungen.
- **ENTSCHEIDUNG 20A-15:** Kosten- und Verbrauchsgrenzen sind Bestandteil des Sicherheits- und Betriebsmodells.
- **ENTSCHEIDUNG 20A-16:** AI Incidents integrieren sich in Security-, Privacy-, Quality- und Business-Incident-Prozesse.

35. Begründete Annahmen

- **ANNAHME 20A-A01:** Ein providerneutrales Gateway ist im Prototyp mit einer kleinen internen Schnittstelle und zwei Adaptern umsetzbar.
- **ANNAHME 20A-A02:** Die größte frühe Wertwirkung entsteht durch Erklären, Suchen, Entwerfen und Reporting, nicht durch autonome Agenten.
- **ANNAHME 20A-A03:** Strukturierte Outputs reduzieren Implementierungs- und Sicherheitsrisiken deutlich gegenüber reinem Freitext.
- **ANNAHME 20A-A04:** Synthetische Golden Sets reichen für den Demonstrator, müssen vor Produktivbetrieb durch fachlich kuratierte reale Testfälle ergänzt werden.
- **ANNAHME 20A-A05:** Nutzer akzeptieren Human Gates, wenn Review schnell, quellenbasiert und rollenbezogen gestaltet ist.
- **ANNAHME 20A-A06:** Ein deterministischer Demo Adapter liefert einen glaubwürdigen Vorführeffekt, sofern er klar gekennzeichnet ist und dieselben Verträge nutzt.
- **ANNAHME 20A-A07:** Die Mehrheit vertraulicher Use Cases kann mit minimiertem Kontext statt vollständiger Dokumentübergabe funktionieren.
- **ANNAHME 20A-A08:** Mehrere Modellklassen sind langfristig wirtschaftlicher und resilienter als ein Universalmodell für alle Aufgaben.
- **ANNAHME 20A-A09:** Providerbedingungen, Modelle und regulatorische Einordnung ändern sich häufig und benötigen laufende Revalidierung.
- **ANNAHME 20A-A10:** AI Literacy und transparente Kennzeichnung erhöhen Nutzung und Qualität stärker als eine „unsichtbare Magie“-Positionierung.

36. Offene Fragen

- **OFFENE FRAGE 20A-Q01:** Welche konkreten Provider und Regionen werden für den ersten Live-Demo-Adapter zugelassen?
- **OFFENE FRAGE 20A-Q02:** Welche maximalen Datenklassen dürfen an externe Modelle gesendet werden?
- **OFFENE FRAGE 20A-Q03:** Wird für Highly Confidential Inhalte ein privater oder dedizierter Modellpfad benötigt?
- **OFFENE FRAGE 20A-Q04:** Welche R2- und R3-Qualitätsschwellen werden je Sprache verbindlich?
- **OFFENE FRAGE 20A-Q05:** Welche Inhalte eines Prompts und Outputs werden zur Fehlersuche gespeichert, ohne Datenminimierung zu verletzen?
- **OFFENE FRAGE 20A-Q06:** Welche Citation- und Groundedness-Validatoren werden technisch gewählt?
- **OFFENE FRAGE 20A-Q07:** Wie wird ein Provider-Modellupdate zuverlässig erkannt und wann erzwingt es Revalidation?
- **OFFENE FRAGE 20A-Q08:** Welche Kundenfreigaben sind für externe Modellverarbeitung im Managed-Service-Vertrag erforderlich?
- **OFFENE FRAGE 20A-Q09:** Welche Use Cases benötigen zusätzliche rechtliche Bewertung nach EU AI Act und branchenspezifischen Regeln?
- **OFFENE FRAGE 20A-Q10:** Wie werden personenbezogene Leistungs- oder Verhaltensdaten in AI-gestützter Ressourcenplanung begrenzt?
- **OFFENE FRAGE 20A-Q11:** Wann ist eine KI-Übersetzung für externe oder auditrelevante Nutzung ausreichend geprüft?
- **OFFENE FRAGE 20A-Q12:** Welche Funktionen werden im ersten Prototyp live und welche ausschließlich im Demo Adapter umgesetzt?

37. Ideenparkplatz

- eigener AI Governance Workspace als zusätzlich buchbarer Managed Service,
- automatische Erstellung eines AI Use Case Registers für Kunden,
- Mapping von KI-Anwendungsfällen auf ISO/IEC 42001, NIST AI RMF und EU-AI-Act-Pflichten,
- private Small Language Models für klassifizierte Inhalte,
- confidential computing für ausgewählte Modellpfade,
- kryptografisch signierte AI Provenance Packages,
- privacy-preserving Practice Intelligence über mehrere Mandanten,

- automatisches Red Teaming und Prompt-Fuzzing in CI/CD,
- Policy-as-Code für Provider-, Model-, Prompt- und Toolfreigaben,
- browserbasierter „Explain this decision“-Modus über alle Plattformobjekte,
- Simulation von Modell-, Kosten- und Providerwechseln,
- AI Quality Marketplace mit kuratierten Evaluatoren und Testpaketen,
- sichere multimodale Auswertung von Diagrammen, Screenshots und Netzwerkplänen,
- Outcome Learning: Vergleich erwarteter und beobachteter Wirkung akzeptierter Vorschläge,
- kundenspezifische Tonalitäts- und Terminologiepakete ohne Fine-Tuning,
- modellgestützte Unterstützung bei AI-Literacy-Trainings und Management Reviews.

38. Dokumentenabhängigkeiten

38.1 Eingehende Abhängigkeiten

- **Dokument 05:** Modul M32 AI Assistance & Guardrails und KI-Fallback als Produktgrundsatz.
- **Dokument 06:** rollenbezogene Kennzeichnung, Confidence, Quellen, Fehler- und Wartezustände.
- **Dokument 07:** digitaler Unternehmenswilling, Objekt-IDs, Provenance und Graphbeziehungen.
- **Dokument 08:** ISMS-Kernprozesse und menschliche Freigabeverantwortung.
- **Dokument 09:** deterministische Reife-, Risiko-, Threat-, Control- und Confidence-Fachverträge.
- **Dokument 10:** Decision Cards, Mission, KPI, Route und Simulation; KI erklärt, ersetzt aber keine Kernberechnung.
- **Dokument 11:** Review, Freigabe, Decision Records, Eskalation und Handover.
- **Dokument 12:** Claim-Modell, Report Snapshot, externe Veröffentlichung und Korrektur.
- **Dokument 13 bis 16:** Managed-Service-Verantwortung, Value Ledger, Ressourcen und Kunden-Lifecycle.
- **Dokument 17:** Connector-, Workflow-, Staging- und Automationstrennung.
- **Dokument 18:** Worker, Queue, Gateway, Observability, Kosten und Laufzeitgrenzen.
- **Dokument 19:** Datenklassifikation, Tenant Isolation, Authorization, Privacy, Audit, Secure SDLC und Incident Gates.

38.2 Ausgehende Abhängigkeiten

- **Dokument 20B:** weist AI Product Owner, AI Security, Data/Privacy, Evaluation, Prompt/RAG und Quality-Agenten zu.
- **Dokument 20C:** setzt Registry, Gateway, Adapter, Evals, Checkpoints, Tests, Repository und Implementierungsreihenfolge um.

38.3 Änderungsregel

Änderungen an Autonomiestufen, R4-Verboten, Human Gates, Provider Policy, Datenklassenzulässigkeit, Training Use, Retrievalberechtigung, Tool Agency, Confidenceberechnung, externem Publishing oder Cross-Tenant Learning benötigen AI-, Security-, Privacy- und Product-Impactanalyse sowie Aktualisierung der abhängigen Dokumente.

39. Öffentliche Referenzquellen

Die folgenden offiziellen Quellen dienen als Governance-, Sicherheits- und Regulierungsanker. Sie ersetzen keine konkrete rechtliche Prüfung, Provider-Due-Diligence oder kundenspezifische Risikobewertung.

- **S1 - Verordnung (EU) 2024/1689 (AI Act), EUR-Lex:** risikobasierter Rechtsrahmen, Transparenz, Governance und Pflichten für bestimmte KI-Systeme und General-Purpose-AI-Modelle. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/deu>
- **S2 - Europäische Kommission, AI Act Framework and Application Timeline:** aktuelle Umsetzungsinformationen; Status und Fristen sind vor Produktivbetrieb erneut zu verifizieren. <https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai>
- **S3 - NIST AI Risk Management Framework 1.0:** vertrauenswürdige AI-Eigenschaften und die Funktionen Govern, Map, Measure und Manage. <https://www.nist.gov/itl/ai-risk-management-framework>
- **S4 - NIST AI RMF Generative AI Profile, NIST AI 600-1:** generative-AI-spezifische Risiken und Maßnahmen über den Lebenszyklus. <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- **S5 - NIST AI RMF Playbook:** praktische Maßnahmen zu Govern, Map, Measure und Manage. <https://airc.nist.gov/airmf-resources/playbook/>
- **S6 - ISO/IEC 42001:2023, AI Management Systems:** Managementsystem für verantwortliche Entwicklung und Nutzung von KI. <https://www.iso.org/standard/42001>
- **S7 - OWASP Top 10 for LLM Applications 2025:** Prompt Injection, Sensitive Information Disclosure, Supply Chain, Poisoning, Improper Output Handling, Excessive Agency, Prompt Leakage, Vector Weaknesses, Misinformation und Unbounded Consumption. <https://genai.owasp.org/llm-top-10/>
- **S8 - OWASP Artificial Intelligence Security Verification Standard 1.0:** testbare Sicherheitsanforderungen für KI-fähige Systeme über den Lebenszyklus. <https://owasp.org/www-project-artificial-intelligence-security-verification-standard-aisvs-docs/>
- **S9 - OWASP Large Language Model Security Verification Standard:** Architektur-, Lifecycle-, Betriebs- und Integrationsanforderungen für LLM-Systeme. <https://owasp.org/www-project-llm-verification-standard/>
- **S10 - ENISA Artificial Intelligence Cybersecurity Challenges:** lebenszyklusorientierte AI Threat Landscape und Schutz der AI Supply Chain. <https://www.enisa.europa.eu/publications/artificial-intelligence-cybersecurity-challenges>
- **S11 - ENISA Securing Machine Learning Algorithms:** Bedrohungen wie Poisoning, adversariale Angriffe und Datenexfiltration sowie Gegenmaßnahmen. <https://www.enisa.europa.eu/publications/securing-machine-learning-algorithms>
- **S12 - EDPB Opinion on AI Models:** Datenschutzfragen zu Anonymität, Rechtsgrundlage und rechtswidrig verarbeiteten personenbezogenen Trainingsdaten. https://www.edpb.europa.eu/news/news/2024/edpb-opinion-ai-models-gdpr-principles-support-responsible-ai_de

40. Änderungsprotokoll

Version	Datum	Status	Änderung
1.0	22.07.2026	Erstellt	Erstfassung der KI-Funktions-, Architektur-, Sicherheits-, Qualitäts-, Provider-, Human-Gate-, Fallback- und Demo-Spezifikation.